

LECTURE 5

Unsupervised Learning Part 2: Anomaly Detection & Cybersecurity

Statistical methods • Isolation Forest • One-Class SVM • Autoencoders • Intrusion detection • Insider threat

Case A: network intrusion (N = 500K packets, 41 features) • Case B: insider threat (500 users, 15 compromised)

AK DHAMIJA, Researcher & Instructor

AI & Machine Learning

dhamija.ak@gmail.com • 9811453163

Clustering vs anomaly detection

Clustering: "group similar things" — needs MOST data to form clusters; anomalies get forced into clusters or noise. **Anomaly detection:** "learn what NORMAL looks like; flag everything that deviates". NO attack labels needed ⇒ catches **zero-day** threats never seen before.

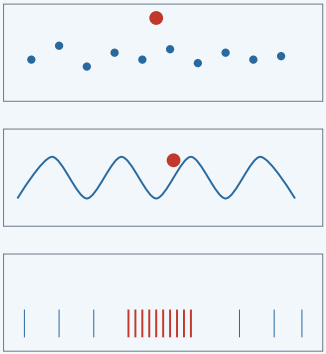
Defence relevance

Network intrusion detection • insider threat (credential compromise) • SIGINT anomalous transmission patterns • wargame and exercise data quality.

Learning objectives

1. Statistical outliers (z-score, Mahalanobis)
2. Isolation Forest: path length → $O(1)$ inference
3. One-Class SVM: ν and the RBF boundary
4. Autoencoder reconstruction-error thresholds
5. Apply all to intrusion and insider threat
6. Evaluate TPR, FPR, AUROC at extreme imbalance

Three types of anomaly



POINT

one login at 3 a.m. from a foreign IP

CONTEXTUAL

big transfer: normal on backup day, not at midnight Tuesday

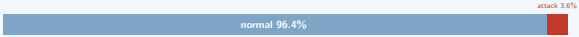
COLLECTIVE

each packet normal; 1,000 in 10 ms = port scan

The Two Case Studies — Network Intrusion and Insider Threat

Case A — network intrusion

500,000 packet records (a 24-hour CERT log): **482,000 normal (96.4%)**, **18,000 attacks (3.6%)**. Attack types: DoS, Probe, R2L (remote-to-local), U2R (user-to-root). 41 packet features: duration, protocol, service, flag, source/destination bytes, wrong fragments, urgent, hot indicators, failed logins, guest login, connection count, SYN-error rate, REJ rate, ... Train 400,000 (normal + 14,400 attacks); test 100,000 (normal + 3,600 attacks).



Case B — insider threat

500 users $\times$ 1,000 log entries $=$ 500,000 activity logs. **Only 15 compromised accounts (0.003%).** 18 behaviour features: login hour, login location (IP subnet), files accessed (count & category), e-mail recipients (internal/external), USB/removable-drive events, after-hours flag, data-transfer volume, privilege-escalation attempts, failed authentications, app-usage deviation.

Imbalance: Case A is 27 : 1; Case B is **33,333 : 1**. Accuracy is useless here: "nothing is ever an attack" scores 99.997% on Case B.

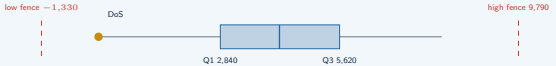
Statistical Anomaly Detection (I) — z-score and IQR Fences (Univariate)



Z-SCORE

$$z_i = \frac{x_i - \mu}{\sigma}, \qquad \text{anomaly if } |z_i| > \tau \ (\tau = 2.5 \text{ or } 3)$$

- Normal: $\mu = 4{,}218$ B, $\sigma = 2{,}104$ B; DoS avg 1.2 B $\Rightarrow z = -2.004$ (**missed** at $\tau = 3$); U2R avg 11,240 B $\Rightarrow z = +3.34$ (**detected**)

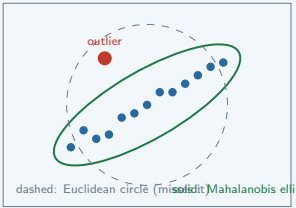


IQR FENCES (ROBUST)

$$x < Q_1 - 1.5\,\text{IQR} \quad \text{or} \quad x > Q_3 + 1.5\,\text{IQR}$$

- $Q_1 = 2{,}840$, $Q_3 = 5{,}620$, IQR $= 2{,}780$ $\Rightarrow$ fences $-1{,}330$ and $9{,}790$

Check the arithmetic: the low fence is *negative*, so DoS at 1.2 bytes lies *inside* it and is not flagged. Univariate methods also see one feature at a time — multi-feature attacks are invisible.

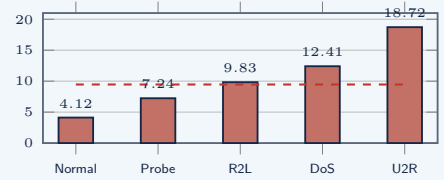


MAHALANOBIS DISTANCE

$$D_M(x) = \sqrt{(x-\mu)^\top \Sigma^{-1} (x-\mu)}$$

- Scales each direction by its variance and accounts for correlations (Σ^{-1})
- $D_M^2 \sim \chi^2_d$ under normality; threshold at 0.1% FPR for $d = 41$: ≈ 9.46

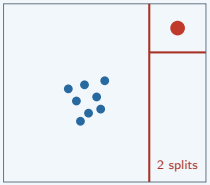
Mean D_M by traffic type (threshold 9.46)



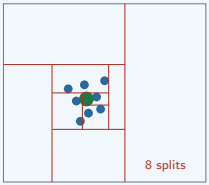
Overall test **TPR 72.1%, FPR 1.8%**. Probes (mean 7.24) fall below the threshold and are often missed; R2L is marginal.

Assumes multivariate Gaussian data — network traffic is heavy-tailed. **Robust variant:** estimate μ, Σ with the Minimum Covariance Determinant (central 50% of data), so the anomalies don't contaminate Σ.

Isolation Forest — Anomalies Are Easier to Isolate Than Normal Points



anomaly: isolated fast



normal point: many splits

ANOMALY SCORE

$$s(x,\psi) = 2^{-E[h(x)]/c(\psi)}, \quad c(\psi) = 2H(\psi-1) - \frac{2(\psi-1)}{\psi}$$

$h(x)$: path length from root to x; $E[h(x)]$: average over B trees; $H(i) \approx \ln i + 0.5772$.

$s \to 1$: anomaly; $s < 0.5$: normal.

Algorithm ($B = 100$ iTrees)

For each tree: (1) sample $\psi = 256$ points; (2) recursively pick a random feature j and a random split $q \in [\min x_j, \max x_j]$; (3) stop when each leaf has one point or height reaches $\log_2 \psi$. Shorter average path $\Rightarrow$ more anomalous.

Why sub-sampling helps

With only 256 of 500K points per tree, normal points still sit among neighbours (many splits), while anomalies remain isolated (few splits): sub-sampling *amplifies* the difference.

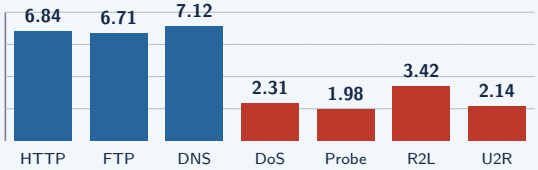
Case A ($B = 100$, $\psi = 256$): TPR **91.4%**, FPR 1.1%, AUROC 0.976.

COST

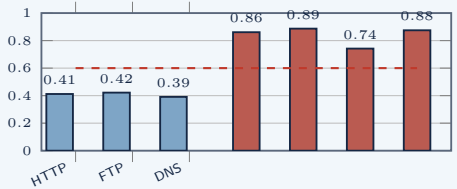
train: $O(B\,\psi \log \psi)$ infer: $O(B \log \psi)$

- $\log_2 256 = 8$ comparisons/tree $\times$ 100 trees $= 800$ comparisons per packet
- Training on Case A: **0.4 s** (vs 38.4 s for OCSVM); inference **0.002 ms**/packet — real time

Expected path length $E[h(x)]$ in 100 trees



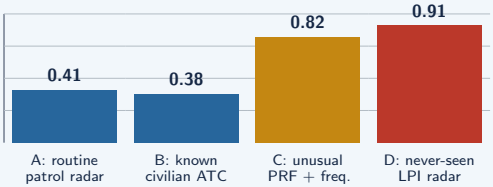
Anomaly score $s(x)$ (threshold 0.60)



Why DoS has a short path: its source bytes ($\approx$1) and connection count (thousands/s) are extreme, so the first random split on either feature isolates it immediately.

Normal SIGINT baseline (90 days)

Frequency 8.42 $\pm$ 0.12 GHz; PRF 1,240 $\pm$ 84 Hz; pulse width 2.1 $\pm$ 0.4 μs; scan rate 6.0 $\pm$ 0.8 deg/s.



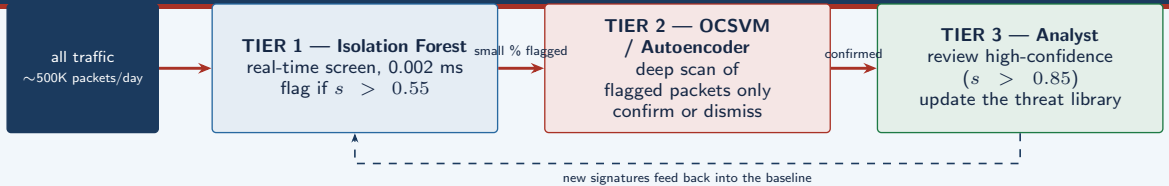
Anomaly scores of four observed signals.

Zero-day detection: signal D was identified as a **Low-Probability-of-Intercept (LPI)** radar — a new signature not in the threat library. No label was needed: its combination of frequency drift and random PRF was statistically unusual against the 90-day baseline.

Operational threshold selection: choose s^* to meet a target FPR $\leq 1\%$ on validation data, then report the TPR that results — never tune the threshold on the test set.

"Unusual" is not "hostile": signal C may be a new civilian system. Every alert needs analyst confirmation before the threat library is updated.

The Recommended 3-Tier Hybrid Detection Architecture

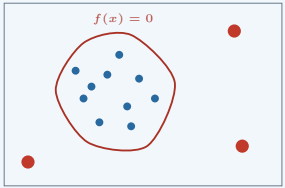


Why three tiers?

Tier 1 buys **speed** (screens everything), tier 2 buys **precision** (expensive models only where needed), tier 3 buys **knowledge** (humans confirm, explain and teach the system).

The same pattern is used in airport security (metal detector → scanner → officer) and in medical screening (cheap test → confirmatory test → specialist): cheap and sensitive first, expensive and specific second.

One-Class SVM — A Tight Boundary Around Normal Data



trained on NORMAL data only

SCHÖLKOPF (2001) FORMULATION

$$\min \ \tfrac{1}{2}\|w\|^2 + \tfrac{1}{\nu N}\sum_i \xi_i - \rho \quad \text{s.t. } w \cdot \phi(x_i) \geq \rho - \xi_i$$

$$f(x) = \text{sign}\Big(\sum_i \alpha_i K(x_i, x) - \rho\Big)$$

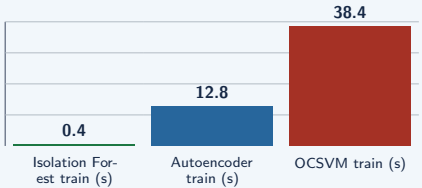
- $f(x) \geq 0$: normal; $f(x) < 0$: anomaly
- $\nu \in (0, 1]$: **upper bound on the fraction of outliers**, lower bound on the fraction of support vectors; $\nu = 0.01$ very tight; start with $\nu \approx$ target FPR
- RBF kernel $K = \exp(-\gamma\|x - x'\|^2)$: non-linear boundary in the original space
- **SVDD** alternative: minimum-radius hypersphere enclosing the data

Grid search: TPR (%) by $\nu \times \gamma$

	γ=0.001	γ=0.01	γ=0.10	γ=1.0
ν=0.01	71	81	87	74
ν=0.05	79	88	89.7	79
ν=0.10	82	89.1	86.3	72
ν=0.20	84	86.4	78.2	64

One-Class SVM — Case A Results and Limitations

Optimal $\nu = 0.05$, $\gamma = 0.10$: test TPR **89.7%**, FPR 0.9%, AUROC 0.971. Training 38.4 s on 482K normal samples; inference 4.2 ms/packet.

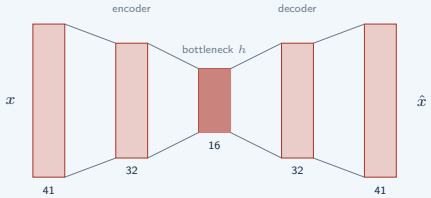


OCSVM limitations

- Training scales as $O(N^2)$: 482K^2 is infeasible $\Rightarrow$ sub-sample 50K normal packets (verified: 88.9% TPR, close to full)
- Sensitive to γ: the wrong value flags everything or nothing
- Not naturally probabilistic — a binary decision only

Use OCSVM for medium datasets where you want a principled, label-free boundary; prefer autoencoders or Isolation Forest at scale.

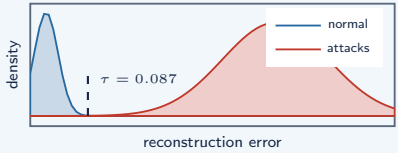
Autoencoders — Compress, Reconstruct: High Error = Anomaly



TRAINING AND DETECTION

$$h = f_{\text{enc}}(x), \quad \hat{x} = f_{\text{dec}}(h), \quad L(\theta) = \frac{1}{N}\sum_i \|x_i - \hat{x}_i\|^2$$

$$\text{RE}(x) = \|x - \hat{x}\|^2 \;\Rightarrow\; \text{anomaly if RE}(x) > \tau$$



Normal RE mean 0.024 (sd 0.018); attack REs 0.29–0.46 by type (schematic shapes).

- Trained on **normal data only**: it learns to rebuild normal traffic well and anything else badly
- Case A: $41 \to 32 \to 16 \to 32 \to 41$; 3,968 weights; Adam, lr 0.001, 50 epochs, batch 512

Types of Autoencoder — and the Case A Result

Vanilla AE (used in Case A)

Encoder–decoder with MSE loss; deterministic bottleneck.

Variational AE (VAE)

Bottleneck is a distribution $\mathcal{N}(\mu, \sigma^2)$; loss = MSE + KL penalty; gives a probabilistic (log-likelihood) anomaly score; smoother reconstructions for images.

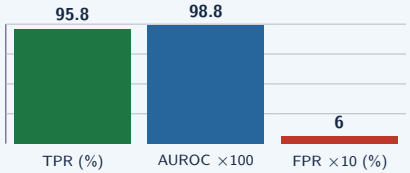
Sparse AE

L1 penalty on activations forces neurons to specialise $\Rightarrow$ better features.

Deep convolutional / LSTM AE

1-D CNN or LSTM encoders capture local and temporal packet-sequence patterns — for sequential traffic and user behaviour (Case B).

Case A: vanilla AE, latent dimension 16

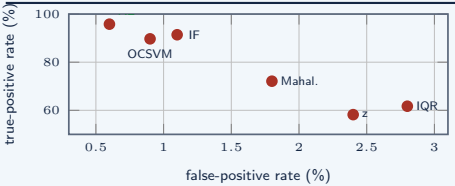


TPR 95.8%, FPR 0.6%, AUROC 0.988 — best of all methods. Training 12.8 s; inference 0.04 ms.

Threshold $\tau = 0.087$ chosen to give FPR $= 0.6\%$ on validation data — the false-alarm budget comes first, the detection rate follows.

Network Intrusion Detection — Case A Head-to-Head on 500K Packets

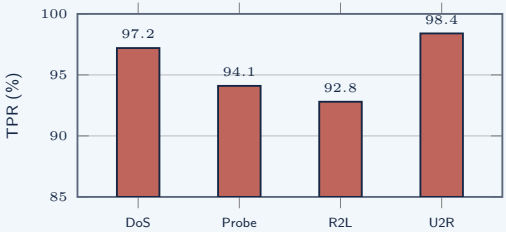
Method	TPR	FPR	AUROC	Train	Infer (ms)	Key limitation
z-score (τ=3)	58.2%	2.4%	0.821	0.1 s	<0.01	univariate; misses multi-feature attacks
IQR fences	61.7%	2.8%	0.834	0.1 s	<0.01	no correlations
Mahalanobis	72.1%	1.8%	0.912	2.4 s	0.03	assumes Gaussian; heavy tails
Isolation Forest	91.4%	1.1%	0.976	0.4 s	**0.002**	threshold tuning; no probabilities
One-Class SVM	89.7%	0.9%	0.971	38.4 s	4.2	slow; not scalable to 500K
Autoencoder	**95.8%**	**0.6%**	**0.988**	12.8 s	0.04	GPU for big networks; black box



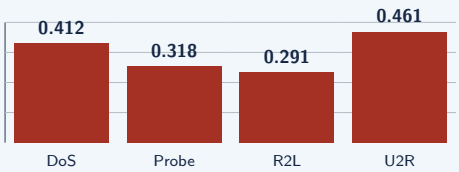
Autoencoder wins on every metric; Isolation Forest is the speed champion (0.002 ms, trains in 0.4 s). Deploy IF as the tier-1 screen and AE as the tier-2 deep scan.

Real-world note: these are KDD-Cup-99 / NSL-KDD-style benchmark results. Real enterprise networks show 10–100× higher FPR from legitimate unusual traffic (backups, batch jobs, patching): re-tune thresholds operationally.

Autoencoder Performance by Attack Type



Attack counts: DoS 12,000; Probe 3,000; R2L 1,800; U2R 1,200.



Mean reconstruction error by attack type (normal mean = 0.024).

U2R (user-to-root) is the hardest attack for statistical methods but the *easiest* for the autoencoder: its feature combination is the most unlike anything in normal traffic. R2L, which imitates legitimate logins, is the hardest for the AE.

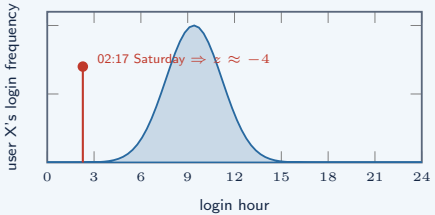
Insider Threat (Case B) — 15 Compromised Accounts in 500,000 Logs

Extreme imbalance

15 of 500,000 entries (0.003%): **33,333**× more normal than anomalous — orders of magnitude more extreme than Case A (3.6%).

User behaviour analytics (UBA)

Instead of per-event detection, build a **behaviour profile per user**: login hour $\mu = 9.4$ h, $\sigma = 1.8$ h; 12–45 files/day; < 50 MB/day transfer; 3–8 unique e-mail recipients/day. Anomaly = deviation from one's *own* baseline. Sequence level: an LSTM autoencoder on 50-event sequences.

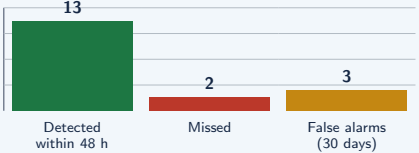


User X normally logs in 9–11 a.m., never at weekends. A 02:17 Saturday login is about four standard deviations from X's own pattern.

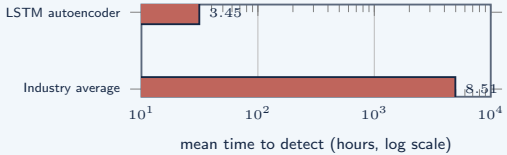
Insider Threat — LSTM Autoencoder Results

Architecture

Input: 50 events × 18 features. Encoder LSTM(64) → LSTM(32) → dense(16); decoder dense(32) → LSTM(64) → output. Trained on 475 non-compromised users. Per-user rolling RE (7-day window): normal baseline 0.031 ± 0.014; threshold $\tau = 0.031 + 3(0.014) = \mathbf{0.073}$.

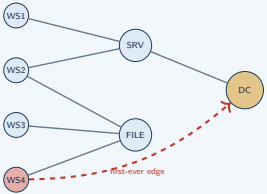


13 of 15 = 86.7% recall; 3 false alarms = 0.63% of 475 users, cleared by analysts within 2 h.



MTTD 31.4 h vs an industry average of 207 days (4,968 h) for insider threats (IBM Cost of a Data Breach 2023).

The 2 missed accounts: senior analysts whose legitimate weekend work was already in their baseline; attackers used the stolen credentials during the victim's normal hours. **Mitigation:** add data-access-category features — no analyst should touch finance + HR + technical files in one session.



$G_t = (V, E_t)$ vs 90-day baseline $G_{\text{base}} = (V, E_{\text{hist}})$

What is lateral movement?

After the initial compromise, the attacker moves through the network toward high-value targets (e.g. the domain controller). Signatures: unusual machine-to-machine connections (a first-time workstation $\rightarrow$ server link); SMB/RPC at odd hours; authentication from unexpected IPs; pass-the-hash (NTLM) patterns.

Anomaly signal: a new edge (u, v) in G_t with no history in G_{base} = high-suspicion event. Only 1.4% of all connections are first-time, so the alert volume stays manageable.

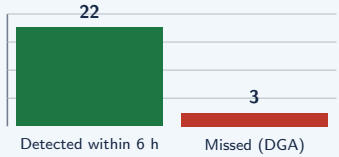
GRAPH AUTOENCODER

$$h = \mathrm{GCN}(A, X), \qquad \tilde{A} = \sigma(hh^\top)$$

$$\text{node RE}_i = \left\| A_{i\cdot} - \tilde{A}_{i\cdot} \right\|^2$$

- C2 malware beacons at near-constant inter-arrival times; JA3 = TLS fingerprint of the C2 client library
- Train the GAE on a 30-day normal network graph; compromised nodes' RE spikes when a C2 edge appears

25 simulated C2 channels, 10,000-node network



88% detected; 4.2 false positives per 10K nodes per day (FPR 0.042%).

The 3 misses used a domain-generation algorithm (DGA) with > 200 randomised domains, avoiding a stable pattern. **Fix:** add a DNS feature such as DGA domain-name entropy.

Algorithm Comparison — Statistical → ML → Deep Learning

Method	Type	TPR	FPR	AUROC	Train	Infer	Explainable
z-score / IQR	statistical	58–62%	2.4–2.8%	0.83	0.1 s	<0.01 ms	yes (intuitive)
Mahalanobis	statistical	72.1%	1.8%	0.912	2.4 s	0.03 ms	yes (distance)
Isolation Forest	ensemble	91.4%	1.1%	0.976	0.4 s	0.002 ms	partial (path)
One-Class SVM	kernel ML	89.7%	0.9%	0.971	38 s*	4.2 ms	limited
Autoencoder	deep	95.8%	0.6%	0.988	12.8 s	0.04 ms	limited (RE)
LSTM autoencoder	deep	86.7%†	0.6%	0.967†	48 s	0.8 ms	limited (RE)
Graph AE	graph ML	88%†	0.04%	0.981†	varies	varies	partial

* needs sub-sampling for $N > 50\text{K}$. † Case B insider / C2 metrics.

Accuracy winner: autoencoder. **Speed winner:** Isolation Forest (0.002 ms/packet enables ∼1M packets/s screening). **Recommended:** 3-tier IF → AE → analyst.

Explainability gap: an RE value doesn't say WHY. For ROE compliance, apply SHAP to the reconstruction-error vector to show which features drove the alert.

Spotting the abnormal is how engineers, doctors and watch-keepers stay alive

ENGINEERING
Shewhart's control charts (Bell Labs, 1920s) flag a process as out of control when a measurement crosses $\pm 3\sigma$ — the z-score rule of this lecture.
Defence: ammunition-lot quality assurance; production-line monitoring for weapons and spares.

AERONAUTICS
Engine health monitoring trends exhaust-gas temperature and vibration against each engine's own baseline to catch deterioration early.
Defence: predictive maintenance of combat aircraft — per-asset baselines, like UBA's per-user profiles.

BIOLOGY / MEDICINE
The immune system separates "self" from "non-self"; Forrest et al. (1994) turned this into artificial immune systems for computer intrusion detection.
Defence: learn "normal" first; anything foreign is suspect — the logic of Case A.

PSYCHOLOGY
Mackworth's clock test (1948), built to study RAF radar operators, showed detection accuracy falling sharply within the first half-hour of watch: the vigilance decrement.
Defence: why automated tier-1 screening must support human analysts.

STATISTICS
Benford's law: leading digits of many real datasets follow a fixed pattern, so fabricated numbers often stand out — used in fraud and audit analytics.
Defence: screening procurement claims and fabricated readiness or casualty reports.

WARGAMING
Anomaly scores on player and agent moves expose exploits, simulator bugs and "gamey" tactics that would never work in reality.
Use: cleaner exercise data and more honest lessons learned.

Common thread: define normal carefully, per asset or per person, and remember the base rate — in every field, most alarms are false unless the threshold is set with care.

Lecture 5 Summary — Anomaly Detection for Defence Cybersecurity

Z-SCORE & MAHALANOBIS
Fast and interpretable; univariate z misses multi-feature attacks; Mahalanobis handles correlations but assumes Gaussian data.
Use: quick baselines

ISOLATION FOREST
Path-length score; 0.002 ms inference; zero-day detection without labels.
Use: real-time tier-1 screening

ONE-CLASS SVM
Tight boundary around normal; ν sets the outlier fraction; RBF kernel.
Use: medium datasets, label-free

AUTOENCODER (DENSE / LSTM)
Reconstruction error = anomaly score; TPR 95.8%, FPR 0.6%; LSTM for behaviour sequences.
Use: accuracy gold standard

GRAPH AE (C2 / LATERAL)
First-time edges and node RE expose lateral movement and C2; add DGA entropy for blind spots.
Use: network graph intelligence

3-TIER DEPLOYMENT
IF screen $\rightarrow$ AE deep scan $\rightarrow$ analyst; insider MTTD 31.4 h vs 207 days.
Use: operational best practice

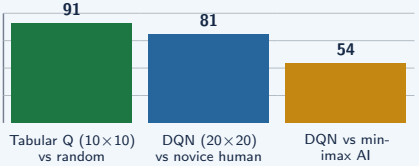
From passive learning to active decision-making

- RL vs supervised / unsupervised
- MDP: S, A, $P(s'|s,a)$, $R(s,a,s')$, γ
- Bellman optimality: $V^*(s)$, $Q^*(s,a)$ derived from scratch
- Q-learning: TD update, ε-greedy, contraction-mapping convergence
- DQN: experience replay; target network; Double and Dueling DQN
- Reward shaping for sparse rewards; curriculum learning

Assignment 5: Isolation Forest path-length calculation + OCSVM ν interpretation + autoencoder threshold derivation.

Preview: wargame tactical agent

20×20 hex JANUS map; state space $\sim 10^{28}$ (no Q-table can hold it); actions {move N/S/E/W, attack, defend, resupply}; reward $+10$ objective, $+5$ kill, -8 unit lost.



DQN: 3 layers × 512 units; 100K-transition replay buffer; target update every 1,000 steps; 100K episodes, 48 GPU-hours.